

VULNERABILITY ASSESSMENT CON NMAP E NESSUS

Obiettivo: Eseguire scansioni di rete, identificare vulnerabilità e valutare i rischi utilizzando strumenti standard di settore come Nmap e Nessus.

Target scelto: Metasploitable - 192.168.20.10

Strumenti utilizzati: Nmap e Nessus Essentials.

1. Sintesi

Rapporto di Vulnerability Assessment realizzato tramite scansioni effettuate con Nmap e Nessus sul target Metasploitable.

In primo luogo è stata effettuata una scansione con Nmap per verificare porte aperte, protocolli utilizzati, versioni dei servizi e sistema operativo. Successivamente, tramite Nessus, è stata realizzata una scansione automatizzata più profonda per individuare vulnerabilità note e possibili azioni correttive.

2. Scansione Nmap

La scansione Nmap è stata utilizzata per individuare host attivi, porte aperte, servizi in esecuzione e informazioni sul sistema operativo del target.

Comando utilizzato:

```
sudo nmap -A -sV -O -oA scan_meta 192.168.20.10
```

I flag utilizzati hanno il seguente significato:

- -A: abilita una scansione approfondita con script NSE, rilevamento OS, versioni e traceroute;
- -sV: rileva la versione dei servizi in esecuzione;
- -O: tenta il riconoscimento del sistema operativo;
- -oA scan_meta: salva l'output nei formati .nmap, .gnmap e .xml.

```

Session Actions Edit View Help
(kali@kali) ~/Desktop
$ sudo nmap -A -v -o scan_meta 192.168.20.10
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2020-07-09 08:04 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Stats: 0:00:50 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.88% done; ETC: 08:05 (0:00:00 remaining)
Stats: 0:01:57 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 93.62% done; ETC: 08:06 (0:00:04 remaining)
Nmap scan report for 192.168.20.10
Host is up (0.0078s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp             vsftpd 2.3.4
|_ ftp-syst:
|_ STAT:
|_ FTP Server status:
|_   Connected to 192.168.20.11
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   vsftpd 2.3.4 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh             OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ ssh-hostkey:
|_   1024 603df:cf1e1c05f6a74d659824fa:ca4d56c:cd (DSA)
|_   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet          Linux telnetd
25/tcp    open  smtp            Postfix smtpd
|_ smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITIME, DSN
53/tcp    open  domain          ISC BIND 9.4.2
|_ dns-nsid:
|_ bind.version: 9.4.2
80/tcp    open  http            Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_ http-title: Metasploitable2 - Linux
111/tcp   open  rpcbind         2 (RPC #100000)
|_ rpcinfo:
|_   program version    port/proto  service
|_   100000 2          111/tcp    rpcbind
|_   100000 2          111/udp    rpcbind
|_   100003 2,3,4      2049/tcp   nfs
|_   100003 2,3,4      2049/udp   nfs
|_   100005 1,2,3      44435/tcp  mountd
|_   100005 1,2,3      53206/udp  mountd
|_   100021 1,3,4      34631/tcp  nlockmgr
|_   100021 1,3,4      40678/udp  nlockmgr
|_   100024 1          34363/tcp  status
|_   100024 1          52963/udp  status
139/tcp   open  netbios-ssn     Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn     Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp   open  exec            netkit-rsh rexecd
513/tcp   open  login

```

Sopra: porte aperte, tra cui FTP, SSH, Telnet, SMTP, DNS, HTTP, RPC e SMB, rilevate dalla scansione nmap

Dai risultati della scansione emerge una superficie di attacco molto ampia. Nmap rileva numerosi servizi esposti, molti dei quali obsoleti o poco sicuri se presenti in un ambiente reale.

Tra i servizi principali individuati sono presenti:

- FTP su porta 21 con vsftpd 2.3.4 e accesso anonimo rilevato;
- SSH su porta 22 con OpenSSH 4.7p1;
- Telnet su porta 23, protocollo non cifrato;
- Apache HTTP su porta 80;
- Samba/SMB sulle porte 139 e 445;
- MySQL su porta 3306 e PostgreSQL su porta 5432;
- VNC su porta 5900;
- Apache Tomcat su porta 8180 e connettore AJP sulla porta 8009.

```
Session  Actions  Edit  View  Help
514/tcp  open  shell      Netkit rshd
1009/tcp open  java-rmi    GNU Classpath gmicregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3300/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 17
|   Capabilities flags: 43564
|   Some Capabilities: Support4IAuth, ConnectWithDatabase, SupportsTransactions, SwitchToSSLAfterHandshake, LongColumnFlag, Speaks41ProtocolNew, SupportsCompression
|   Status: Autocommit
|   Salt: 5(FM/244Q0w,0lQ3GM+..
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
| ssl-date: 2026-07-09T12:05:30+00:00; -5s from scanner time.
| ssl-cert: Subject: commonName=ubuntu04-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2018-03-17T14:07:45
| Not valid after: 2018-04-16T14:07:45
5900/tcp open  vnc         VNC (protocol 3.3)
| vnc-info:
|   Protocol version: 3.3
|   Security types:
|     _ VNC Authentication (2)
| 6000/tcp open  x11        (access denied)
6667/tcp open  irc        UnrealIRCd
8009/tcp open  ajp13      Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http       Apache Tomcat/Coyote JSP engine 1.1
|_http-favicon: Apache Tomcat
|_http-title: Apache Tomcat/5.5
MAC Address: 08:00:27:ED:05:86 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|   System time: 2026-07-09T08:05:01-04:00
|_smb2-time: Protocol negotiation failed (SMB2)
|_clock-skew: mean: 1h19m54s, deviation: 2h18m34s, median: -5s
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_smb-security-mode:
|   account used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)

TRACEROUTE
Hop RTT ADDRESS
1 7.83 ms 192.168.20.10

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 151.73 seconds
```

Sopra: servizi esposti, tra cui MySQL, PostgreSQL, VNC, X11, IRC, AJP e Tomcat, dalla scansione nmap

Nmap ha inoltre identificato il target come sistema Linux 2.6.x, coerente con Metasploitable. La presenza di protocolli non cifrati, servizi legacy e database esposti rappresenta un rischio elevato in un contesto aziendale reale.

```
Session  Actions  Edit  View  Help
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 17
|   Capabilities flags: 43564
|   Some Capabilities: Support4IAuth, ConnectWithDatabase, SupportsTransactions, SwitchToSSLAfterHandshake, LongColumnFlag, Speaks41ProtocolNew, SupportsCompression
|   Status: Autocommit
|   Salt: 5(FM/244Q0w,0lQ3GM+..
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
| ssl-date: 2026-07-09T12:05:30+00:00; -5s from scanner time.
| ssl-cert: Subject: commonName=ubuntu04-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2018-03-17T14:07:45
| Not valid after: 2018-04-16T14:07:45
5900/tcp open  vnc         VNC (protocol 3.3)
| vnc-info:
|   Protocol version: 3.3
|   Security types:
|     _ VNC Authentication (2)
| 6000/tcp open  x11        (access denied)
6667/tcp open  irc        UnrealIRCd
8009/tcp open  ajp13      Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http       Apache Tomcat/Coyote JSP engine 1.1
|_http-favicon: Apache Tomcat
|_http-title: Apache Tomcat/5.5
MAC Address: 08:00:27:ED:05:86 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|   System time: 2026-07-09T08:05:01-04:00
|_smb2-time: Protocol negotiation failed (SMB2)
|_clock-skew: mean: 1h19m54s, deviation: 2h18m34s, median: -5s
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_smb-security-mode:
|   account used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)

TRACEROUTE
Hop RTT ADDRESS
1 7.83 ms 192.168.20.10

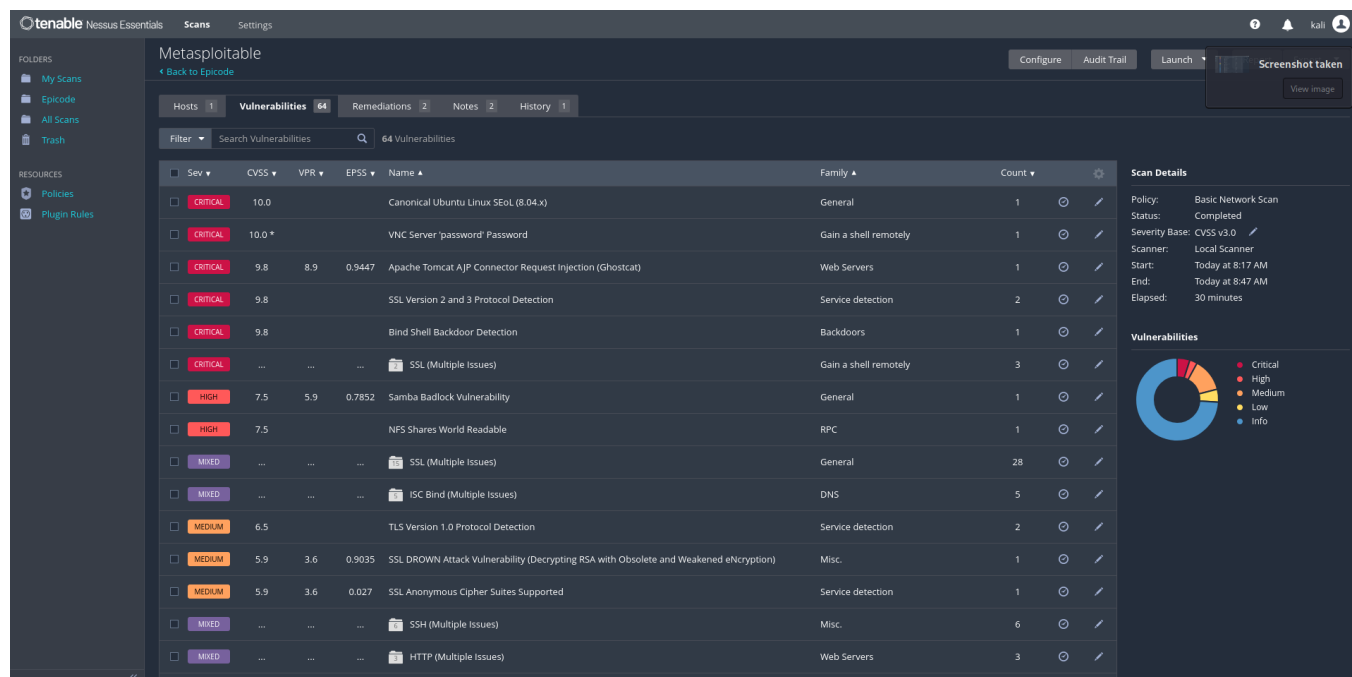
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 151.73 seconds
```

Sopra: informazioni sul sistema operativo, NetBIOS, SMB e traceroute verso il target rilevate dalla scansione Nessus

3. Scansione Nessus

Dopo la scansione Nmap è stata eseguita una scansione con Nessus Essentials. Con lo scopo di individuare vulnerabilità note, classificarle per severità e ottenere indicazioni sulle possibili soluzioni.

La scansione Nessus è stata configurata come Basic Network Scan verso il target Metasploitable. Il risultato mostra 64 vulnerabilità complessive, con diverse criticità classificate come Critical e High.



Sopra: riepilogo della scansione Nessus su Metasploitable. Sono presenti vulnerabilità critiche, alte, medie, basse e informative.

Tra le vulnerabilità più rilevanti rilevate da Nessus sono presenti:

- Canonical Ubuntu Linux SEoL (8.04.x): sistema operativo non più supportato
- VNC Server password Password: presenza di password debole
- Apache Tomcat AJP Connector Request Injection (Ghostcat)
- SSL Version 2 and 3 Protocol Detection: protocolli SSL obsoleti
- Bind Shell Backdoor Detection: presenza di una backdoor esposta
- Samba Badlock Vulnerability
- NFS Shares World Readable: condivisioni NFS leggibili pubblicamente

tenable

Nessus Essentials

Scans

Settings

Settings

Scans

6.5

TLS Version 1.0 Protocol Detection

Service detection

2

My Scans

Epicode

All Scans

Trash

Policies

Plugin Rules

MEDIUM

5.9

3.6

0.9035

SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened eNcryption)

Misc.

1

MEDIUM

5.9

3.6

0.027

SSL Anonymous Cipher Suites Supported

Service detection

1

MIXED

...

...

...

SSH (Multiple Issues)

Misc.

6

MIXED

...

...

...

HTTP (Multiple Issues)

Web Servers

3

MIXED

...

...

...

SMB (Multiple Issues)

Misc.

2

MIXED

...

...

...

TLS (Multiple Issues)

Misc.

2

MIXED

...

...

...

TLS (Multiple Issues)

SMTP problems

2

LOW

2.6 *

X Server Detection

Service detection

1

LOW

2.1 *

2.9

0.0037

ICMP Timestamp Request Remote Date Disclosure

General

1

INFO

...

...

...

SMB (Multiple Issues)

Windows

7

INFO

...

...

...

TLS (Multiple Issues)

General

4

INFO

...

...

...

DNS (Multiple Issues)

DNS

3

INFO

...

...

...

VNC (Multiple Issues)

Service detection

3

INFO

...

...

...

Apache HTTP Server (Multiple Issues)

Web Servers

2

INFO

...

...

...

FTP (Multiple Issues)

Service detection

2

INFO

...

...

...

PHP (Multiple Issues)

Web Servers

2

INFO

...

...

...

RPC (Multiple Issues)

RPC

2

INFO

...

...

...

SSH (Multiple Issues)

General

2

INFO

...

...

...

SSH (Multiple Issues)

Service detection

2

Sopra: vulnerabilità di livello medio e basso individuate da Nessus

Oltre alle vulnerabilità critiche, Nessus ha rilevato diverse informazioni utili sul target: servizi in ascolto, versioni software, identificazione del sistema operativo e dati relativi ai protocolli utilizzati.

tenable

Nessus Essentials

Scans

Settings

FOLDERS

My Scans

Epicode

All Scans

Trash

RESOURCES

Policies

Plugin Rules

INFO

Nessus SYN scanner

Port scanners

25

INFO

RPC Services Enumeration

Service detection

10

INFO

Service Detection

Service detection

7

INFO

Remote Services Not Using Post-Quantum Ciphers

General

3

INFO

Unknown Service Detection: Banner Retrieval

Service detection

3

INFO

OpenSSL Detection

Service detection

2

INFO

RMI Registry Detection

Service detection

2

INFO

AJP Connector Detection

Service detection

1

INFO

Backported Security Patch Detection (WWW)

General

1

INFO

Common Platform Enumeration (CPE)

General

1

INFO

Device Type

General

1

INFO

Ethernet Card Manufacturer Detection

Misc.

1

INFO

Ethernet MAC Addresses

General

1

INFO

IRC Daemon Version Detection

Service detection

1

INFO

Nessus Scan Information

Settings

1

INFO

NFS Share Export List

RPC

1

INFO

OpenSSH Detection

Misc.

1

INFO

OS Fingerprints Detected

General

1

INFO

OS Identification

General

1

INFO

OS Security Patch Assessment Not Available

Settings

1

Sopra: risultati informativi della scansione Nessus, utili per comprendere i servizi attivi e le tecnologie esposte dal target.

4. Analisi dei rischi

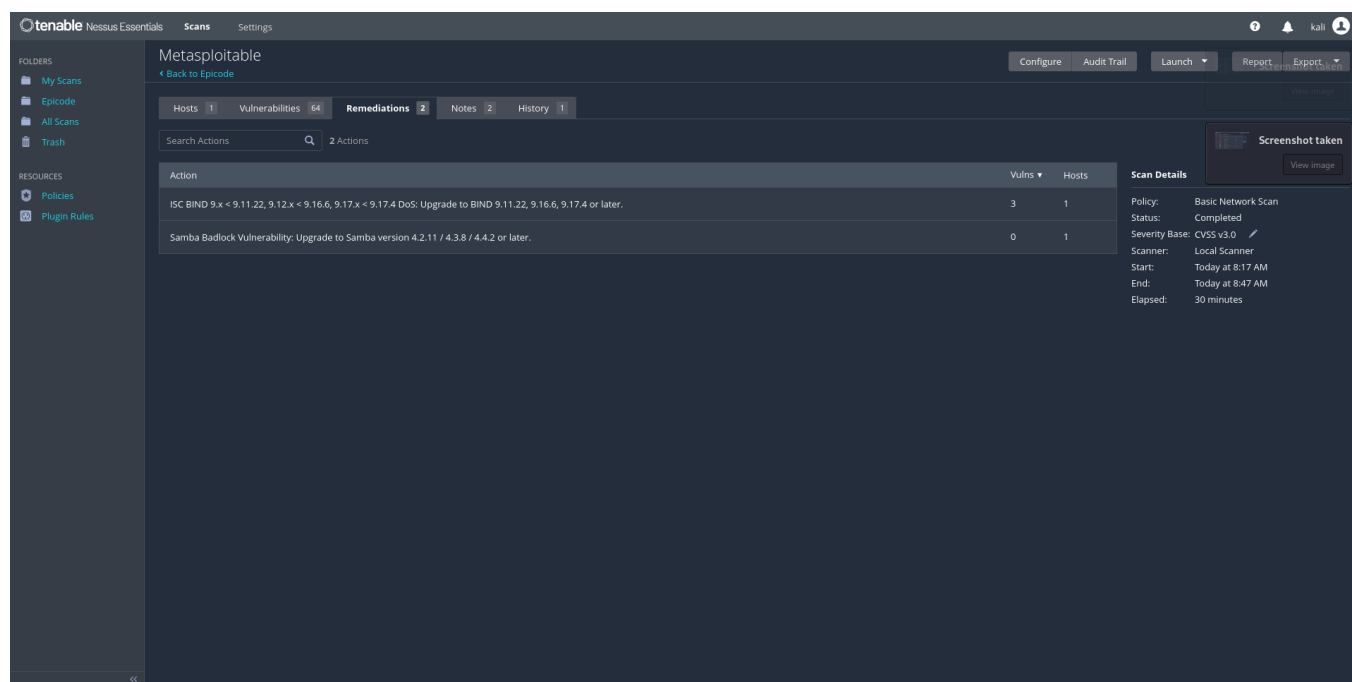
L'analisi combinata di Nmap e Nessus mostra un rischio complessivo molto elevato. Metasploitable espone molti servizi non aggiornati, protocolli non cifrati e componenti vulnerabili. Questo tipo di configurazione, in un ambiente reale, potrebbe permettere accessi non autorizzati o esecuzione di codice remoto.

I rischi principali individuati sono:

- compromissione remota del sistema tramite servizi vulnerabili
- accesso non autorizzato tramite credenziali deboli o servizi mal configurate
- intercettazione di dati tramite protocolli non cifrati come Telnet o FTP
- esposizione di database e condivisioni di rete
- utilizzo di software fuori supporto

5. Remediation e raccomandazioni

Nessus ha individuato alcune azioni correttive prioritarie, in particolare l'aggiornamento di BIND alle versioni 9.11.22, 9.16.6, 9.17.4 o successive e Samba alle versioni 4.2.11 / 4.3.8 / 4.4.2 o successive.



Sopra: sezione Remediations di Nessus. Vengono suggeriti aggiornamenti per BIND e Samba come interventi correttivi prioritari.

In un contesto reale, le principali azioni difensive sarebbero:

- aggiornare o sostituire sistemi operativi e servizi fuori supporto
- disabilitare servizi non necessari
- limitare l'accesso ai servizi tramite firewall e segmentazione di rete

- proteggere gli accessi amministrativi con password più robuste e complesse
- applicare patch management periodico e scansioni di vulnerabilità ricorrenti

6. Conclusioni

Nmap è risultato utile per ottenere una prima panoramica del target, mostrando porte aperte, servizi e versioni. Nessus ha invece permesso di associare queste esposizioni a vulnerabilità note, livelli di rischio e possibili soluzioni.

In un ambiente reale, un risultato simile richiederebbe interventi immediati per ridurre la superficie di attacco e proteggere i sistemi critici.